



Esercizio EpiCode

Attacchi alle reti 2

ESERCIZIO EPICODE WEEK 15 DAY 4 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	3 - 5
Conclusione.....	5

Executive Summary

Nel corso di questo esercizio sono stati analizzati due scenari di sicurezza tipici delle reti locali: **Null Session** (ambito SMB/Windows) e **ARP Poisoning** (ambito rete LAN). L'obiettivo è comprendere il funzionamento di queste vulnerabilità, i contesti in cui si manifestano, i rischi associati e le principali contromisure applicabili.

In particolare, la Null Session evidenzia come configurazioni SMB obsolete o errate possano consentire raccolta di informazioni senza autenticazione, mentre l'ARP Poisoning dimostra come un attaccante in rete locale possa dirottare traffico e realizzare attacchi di tipo **Man-in-the-Middle (MITM)**.

L'esercizio sottolinea l'importanza di hardening, aggiornamenti, segmentazione di rete e monitoraggio continuo per ridurre l'esposizione a queste minacce.

Introduzione

Questo laboratorio è diviso in due parti e si concentra su vulnerabilità e tecniche spesso utilizzate durante attività di penetration testing e assessment di sicurezza in ambienti di rete aziendali.

La prima parte richiede una spiegazione teorica e pratica di concetti fondamentali come **Null Session** e **ARP Poisoning**, includendo i sistemi vulnerabili e le strategie di mitigazione. La seconda parte introduce **Ettercap**, uno strumento utilizzabile sia per analisi di rete sia per simulare attacchi MITM in contesti controllati e autorizzati.

Obiettivo

L'obiettivo dell'esercizio è:

- definire e descrivere brevemente il concetto di **Null Session**
- identificare i sistemi potenzialmente vulnerabili a Null Session e valutarne l'attualità
- elencare le principali mitigazioni per ridurre o eliminare la vulnerabilità Null Session
- spiegare il funzionamento dell'**ARP Poisoning** e i rischi collegati
- indicare i sistemi vulnerabili ad ARP Poisoning all'interno di una rete LAN
- descrivere tecniche e controlli per mitigare, rilevare e contrastare un attacco ARP Poisoning
- comprendere il ruolo di strumenti come **Ettercap** nello studio degli attacchi MITM in ambiente etico e controllato

Proof of Concept pt.1

1) Cosa vuol dire "Null Session" (breve)

La **Null Session** è una connessione anonima (senza credenziali) verso un sistema Windows tramite **SMB/RPC** (porte 139/445), dove l'utente si autentica con **username vuoto e password vuota**. In alcuni casi permette di ottenere informazioni sensibili come **utenti, gruppi, condivisioni e policy**, facilitando la fase di ricognizione.

2) Sistemi vulnerabili a Null Session e se sono ancora in commercio

Sono stati storicamente vulnerabili:

- **Windows NT 4.0**
- **Windows 2000**
- **Windows XP**
- **Windows Server 2003**
- alcuni sistemi **Windows non aggiornati/mal configurati** con SMB attivo

Oggi in commercio:

- questi sistemi sono **obsoleti (EOL) e non più supportati**
- però possono ancora essere presenti in reti legacy (aziende vecchie / ambienti industriali)

3) Modalità per mitigare/risolvere la Null Session

Le mitigazioni principali sono:

- **Disabilitare l'accesso anonimo SMB/RPC**
- Applicare policy Windows:
 - "Restrict anonymous access"
 - "Do not allow anonymous enumeration of SAM accounts and shares"
- Limitare le porte **139/445** tramite firewall (accesso solo da host autorizzati)
- Disabilitare SMBv1 se presente
- Tenere Windows aggiornato (patch + hardening)
- Monitorare eventi e log relativi a tentativi di accesso anonimo

4) Come funziona l'ARP Poisoning

L'**ARP Poisoning (ARP Spoofing)** è un attacco di tipo **Man-in-the-Middle** che sfrutta il protocollo **ARP** (usato in LAN per associare IP ↔ MAC).

L'attaccante invia risposte ARP false alla rete, facendo credere alle vittime che il suo MAC address sia quello del **gateway** (o di un altro host).

Risultato: il traffico passa attraverso l'attaccante, che può **intercettare, modificare o bloccare** i pacchetti.

5) Sistemi vulnerabili ad ARP Poisoning

Sono vulnerabili praticamente **tutti i dispositivi in una rete LAN** che usano ARP e non hanno protezioni specifiche, ad esempio:

- Windows
- Linux
- macOS
- stampanti e IoT
- smartphone (quando connessi in Wi-Fi)
- apparati di rete in LAN "flat" senza difese

In generale: **qualsiasi rete locale non segmentata** è un target perfetto.

6) Mitigare / rilevare / annullare ARP Poisoning

Mitigazione

- **Dynamic ARP Inspection (DAI)** su switch gestiti
- **Port Security** sugli switch
- **Segmentazione VLAN** (riduce superficie d'attacco)
- Tabelle ARP statiche (utile ma poco scalabile)
- Usare protocolli cifrati:
 - HTTPS invece di HTTP
 - SSH invece di Telnet

- VPN dove possibile (riduce sniffing utile)

Rilevazione

- IDS/IPS (Snort, Suricata)
- Tool di detection:
 - arpswatch
 - strumenti di monitoring su rete
- Controllare anomalie tipo:
 - più IP associati allo stesso MAC
 - variazioni improvvise della cache ARP

Annullare / risposta immediata

- Scollegare l'host sospetto
- Ripulire ARP cache (temporaneo)
- Riavviare interfacce / router
- Abilitare DAI e bloccare MAC non autorizzati

Proof of Concept pt.2

Conclusione

L'esercizio ha evidenziato come vulnerabilità legate a configurazioni di rete e protocolli storici possano ancora rappresentare un rischio concreto, specialmente in ambienti legacy o LAN non segmentate.

La **Null Session** dimostra come un'esposizione non corretta di SMB possa facilitare attività di enumerazione e raccolta informazioni senza autenticazione, mentre l'**ARP Poisoning** mostra come, in una rete locale, un attaccante possa intercettare e manipolare il traffico attraverso tecniche di spoofing.

Per ridurre tali rischi è fondamentale applicare hardening e patching, limitare l'esposizione dei servizi, segmentare correttamente la rete e implementare strumenti di detection e protezione (es. DAI sugli switch, firewalling e monitoraggio continuo).

In un contesto reale, l'applicazione di queste misure è essenziale per prevenire compromissioni e attacchi Man-in-the-Middle.

Venezia, 12/01/2026

Fabio Renna

